



Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Grupo: 4

Semestre: 2027-1

Tarea 2

Zero Day Market

Fecha de Entrega:

12 de Septiembre del 2026



Índice

1	¿Qué es una vulnerabilidad de día cero?	1
2	Describa qué es un exploit.	1
3	Explique en qué consiste el mercado gris de exploits.	1
4	Explique en qué consiste el mercado negro de exploits.	2
5	Explique quiénes son los participantes de los mercados de exploits.	2
6	Explique cuáles son los objetivos típicos de los compradores de exploits en el mercado negro.	3
7	Desde su punto de vista y experiencia, ¿cuál es el papel que juega la ética profesional en el ecosistema del mercado de “zero-days”?	4
	Referencias	5



1. ¿Qué es una vulnerabilidad de día cero?

En el video nos ponía el ejemplo directo de un gran muro que protege los sistemas de información, hablando de los sistemas operativos Windows 10 y macOS. Tal cual, se nos decía que, si el código de un sistema operativo es un muro de millones de ladrillos, una vulnerabilidad la catalogaba como un ladrillo defectuoso. Para las empresas, lo ideal es reemplazar ese ladrillo defectuoso y reemplazarlo. No obstante, la importancia de una falla de seguridad se mide por el tiempo de descubrimiento del problema, pero es ahí cuando la empresa se debería dar cuenta. Ahora bien, en el video se trata la vulnerabilidad de día cero, cuando la compañía del software no tiene ninguna idea de que ese error existe en su código; es decir, han tenido cero días de conocimiento sobre la falla, y esto es lo preocupante, porque a partir de esto se puede explotar a más no poder. De hecho, en el video se nos dice que es el “Santo grial del hacking”, ya que puede ser usada para vulnerar dispositivos, aplicaciones o redes, todo esto sin que nadie sospeche la intrusión, pues, al no ser de conocimiento público, no existe ningún parche que la solucione.

2. Describa qué es un exploit.

Un exploit es la herramienta, programa o técnica empleada específicamente para aprovechar una vulnerabilidad que es lo que se nos decía que era el ladrillo defectuoso, donde la intención es atravesar la seguridad de un sistema. De hecho, la parte más importante, también se nos dice, que este puede ser comprado a un tercero, donde solo es confirmar la vulnerabilidad y explotarla: “Un programa malicioso que puede convertir de forma confiable un fragmento de código defectuoso en un paso seguro a través del muro”. En otras palabras, un exploit se diseña para infectar dispositivos, tal es el ejemplo que se nos puso que fue el del iPhone a través de iMessage, tomando el control silenciosamente al aprovechar esas fallas de diseño del software, relacionado con lo visto en clase en el video se nos da el código con el cual se puede identificar esta vulnerabilidad, siendo el código: “CVE-2023-41990”. Por mencionarlo, este mismo ataque se nos dice que fue muy sofisticado, esto porque es una serie de encadenamientos de múltiples vulnerabilidades de día cero sucesivas, así hasta hacerlo más fuerte. En resumen de esto, el exploit puede encontrar aún más vulnerabilidades y explotarlo nuevamente.

En este caso, estas vulnerabilidades fueron 4 de día cero y fue catalogado como “Operation Triangulation”.

3. Explique en qué consiste el mercado gris de exploits.

El mercado gris de exploits es una parte donde diferentes corporaciones y personas independientes como los investigadores, trabajando con alta discreción todo esto para poder comercializar vulnerabilidades sin hacerlas del conocimiento público. A diferencia del mercado blanco, donde directamente cada vulnerabilidad se notifica de forma casi inmediata cuando se descubre a los fabricantes de software para que lancen un parche, no que en el mercado gris las personas que lo descubren mantienen ocultos sus descubrimientos. De hecho, en el video se nos menciona que, en este mercado blanco, las empresas pueden llegar a pagar a hackers que encuentren vulnerabilidades como recompensa por su trabajo.



Como en el video se nos menciona, los principales interesados son los gobiernos y agencias de inteligencia, que son las inversoras en este sector, comprando y almacenando estos secretos informáticos para utilizarlos en operaciones encubiertas, espionaje, vigilancia, justificándose usualmente en la seguridad nacional.

Cabe recalcar que este se considera mercado gris y no negro, porque, como bien mencioné antes, este lo usan empresas estatales, gobiernos y agencias de inteligencia, que teóricamente operan legalmente desde un punto de vista institucional, pero esto se hace de forma anónima.

4. Explique en qué consiste el mercado negro de exploits.

Mientras que en el mercado gris los compradores son gobiernos y buscan la seguridad nacional, en teoría, el mercado negro es un ecosistema completamente ilícito y destructivo de este ecosistema, en la cual las vulnerabilidades de día cero se compran y venden con fines de cibercrimen y extorsión, todo esto para sabotaje o el robo de información.

Tal es el caso de la herramienta de MOVEit, que varias empresas como Sony, Shell y una corporación de EE. UU. usaban. Al momento de ser adquirida por un tercero, se utilizó para robar los datos de los clientes por medio de una vulnerabilidad de día cero. Después de esto, pidieron un rescate por todos estos datos; en el video nunca se menciona cuántas empresas cedieron.

En este espacio operan los cárteles criminales y sindicatos de hacking como los grupos creadores de ransomware que adquieren estas herramientas para realizar ataques a gran escala.

Aquí, donde se busca directamente lucrar con los datos robados, todo esto por medio de daños a la infraestructura, encriptando información y exigiendo millonarios rescates.

5. Explique quiénes son los participantes de los mercados de exploits.

Para esto el mercado de los exploits se estructura de tres participantes:

- **Los investigadores y hackers (Vendedores):** Estas son personas con habilidades para encontrar vulnerabilidades, todo esto por medio de auditorías controladas del código para encontrar defectos explotables. Como bien se menciona en el video, algunos de estos comparten información de exploits gratis por prestigio; no obstante, actualmente buscan compensaciones económicas más grandes, tal cual como el exploit que se vendió por 20 millones de dólares; todo esto ahora sí se vende al mejor postor. En el video se mencionan algunos de estos creadores, como pneumonics, Alf, one pack y nisy.
- **Los compradores:** Ahora bien, en cuestión de esta facción está conformada por gobiernos, agencias de inteligencia, corporaciones y cárteles criminales. Todos ellos quieren algo, que es la información, ya sea “por seguridad nacional” o simplemente para extorsionar; todos estos pujan con presupuestos muy grandes por adquirir fragmentos de información que pueden cambiar el rumbo de un conflicto cibernético.



- **Los intermediarios o “Brokers”:** Estos son un grupo de personas más especializadas, esto debido al grave problema de confianza mutua; surgieron los “Zero-Day Brokers”, por poner el ejemplo del video que se nos menciona. Todos estos son individuos y empresas de dudosa procedencia, las cuales operan como mediadores.

Conectan a los compradores anónimos con los hackers, retienen el exploit y los fondos en un depósito de garantía que es el escrow, y se encargan de comprobar que la vulnerabilidad realmente funcione antes de liberar los pagos.

La estructura mencionada es la siguiente:

- (Matchmakers): Conectan a los vendedores de exploits con los compradores correctos.
- (Escrow): Operan como un fideicomiso para asegurar la confianza tanto del lado del comprador como del vendedor.
- Verificadores: Prueban y confirman que el exploit realmente funciona antes de que se pague por él.

6. Explique cuáles son los objetivos típicos de los compradores de exploits en el mercado negro.

Los compradores que directamente compran dentro del mercado negro tienen intenciones maliciosas que giran en torno al fraude y el cibercrimen. Sus objetivos, que se dejaron ver en el video, son:

- Romper las barreras de seguridad de redes e instituciones, todo esto sin ser detectados para desplegar el ransomware y extorsionar a las víctimas.
- Tomar el control y comprometer sistemas de infraestructura que sean importantes para la empresa a la que se está atacando.
- Infiltrarse silenciosamente para robar información que pocos deben conocer; además de esto, también filtrar bases de datos que luego son monetizadas o explotadas para sabotaje.
- Extorsionar directamente a las empresas afectadas mediante el uso de algún exploit, esto para conseguir dinero.

Aunque, de todo esto, como bien lo dice el video, la principal son las organizaciones que compran en el mercado negro vulnerabilidades de día cero para robar datos.



7. Desde su punto de vista y experiencia, ¿cuál es el papel que juega la ética profesional en el ecosistema del mercado de “zero-days”?

Para este punto, la información de verdad es un punto crucial, la cual para muchas empresas es ya directamente la moneda de cambio para publicidad o para otras empresas. Ahora bien, desde un punto de la ética profesional, a nosotros como ingenieros se nos dice que tenemos que reportar cualquier vulnerabilidad o alguna cosa que haga daño a una persona que esté utilizando los productos que llegáramos a hacer.

Para este punto, nosotros, como ingenieros en computación, ya sea que nos especialicemos en ciberseguridad o no, lo correctamente ético es informar a cualquier empresa que tenga un producto con alguna falla, esto porque, como bien se nos dice en el video, un software que tenga una vulnerabilidad de día cero puede ser explotado por cualquier persona, y esto puede traer consecuencias para las personas que lo estén usando, lo que provocará que, si nosotros no lo reportamos y alguien más lo descubre y lo explota, nosotros tendremos una parte de esa responsabilidad de los daños que se le provocó a esa persona.

La ética profesional solo apoya el mercado blanco, ya que directamente este mercado si opera de forma legal como bien se mencionó en el video. Empresas como Microsoft, Apple y Google tienen programas de recompensas para los investigadores que reporten vulnerabilidades, y esto es lo correcto, ya que, si nosotros como ingenieros en computación, reportamos estas vulnerabilidades, las empresas pueden hacer un parche para que nadie más pueda explotar esta vulnerabilidad, y esto es lo correcto.

Ahora bien, en el mercado gris, aquí, desde lo que he leído antes, existe un caso de una agencia de gobierno que me llamó la atención. Esta es la NSA. Como tal, la NSA descubrió una vulnerabilidad en Windows; esto lo descubrió desde el 2012, pero fue reportada hasta el 2017. Esto no fue porque la NSA la quisiera reportar, sino que fue porque en 2016 un grupo de hackers autodenominado The Shadow Brokers logró infiltrarse en los servidores de la NSA y logró robar varios secretos de la agencia. Entre ellos estaba esa vulnerabilidad que se denominaba como “EternalBlue”, y fue utilizada para propagar el ransomware WannaCry, que afectó a miles de computadoras en todo el mundo. No obstante, la NSA reportó esta falla a Microsoft para que pudiera lanzar el parche lo más rápido posible, pero fue un poco tarde, porque los ataques apenas estaban empezando, lo que provocó que fuera una de las fallas de día cero que más expuso a personas. Esto ya es considerado mercado gris, como bien se menciona en el video, pero esto ya no es éticamente correcto, porque este mercado trabaja en los límites de la legalidad, pero ya no es ético. Si tan solo la NSA hubiera reportado esta vulnerabilidad desde el 2012, esto no hubiera pasado, y muchas personas no hubieran sido afectadas.

Ahora bien, desde mi experiencia como tal en desarrollo web, he llegado a ver cómo varias páginas tienen scripts que son vulnerables, esto siendo páginas que no han sido catalogadas como seguras, lo que de igual forma provoca que fueran explotadas. Todo esto, lo poco que he visto, ha sido reportado, ya que esto es lo correcto éticamente. Al final de todo, no sabremos si en algún momento toda esa información puede llegar a manos de personas equivocadas, lo que pudiera provocar extorsiones o hasta atacar contra la vida de alguien, si es que llegara el caso.



Referencias

Cybernews. (2024, mayo). Where People Go When They Want to Hack You [Accedido el 7 de septiembre de 2026]. <https://www.youtube.com/watch?v=TLPHmHPaCiQ>